FlexiTap POS Platform

ENTERPRISE SECURITY, ARCHITECTURE, PAYMENT & COMPLIANCE REVIEW

FORMAL INDEPENDENT REVIEW DOSSIER

Platform Architecture, Security Hardening, Payment Boundary & Regulatory Compliance Report

A comprehensive technical and legal dossier prepared for independent third-party audit, technical due diligence, enterprise merchant assessment, and regulatory verification across POS registers, cloud infrastructure, web portals, and legal contracts.

TARGET SOFTWARE
FlexiTap POS Engine v2.0 (Flutter), Web Back Office & Supabase Cloud

AUDIT SCOPE
1. Architecture | 2. Security | 3. Payment | 4. Terms, Privacy & Refunds | 5. Audit Matrix

COMPLIANCE BASELINES
PCI DSS v4.0 (Scope Exclusion), GDPR, CCPA/CPRA, RA 10173 (DPA), BIR RR 11-2004, US FLSA

DOCUMENT STATUS & DATE
Active Production Baseline • October 2026

1. Technical System Architecture

1.1 Offline-First POS Engine (Edge Execution)

The core FlexiTap Point-of-Sale client is engineered in **Flutter (Dart)**, compiling to native binaries for Android, Windows, macOS, iOS, and Linux. The POS is built upon an **offline-first local database paradigm** powered by SQLite (sqflite).

- **Autonomous Checkout & Settlement:** Order creation, line item customization, kitchen ticket printing, receipt generation, split billing, table mapping, and shift drawer reconciliations run with **100% zero network dependency**. Network outages never halt lane checkout operations.
- **Atomic Local Ledgers:** All monetary calculations (gross sales, discounts, surcharges, VAT/service charges, cash drawer movements, and Accounts Receivable customer balances) execute within ACID-compliant local transactions.
- **Tamper-Resistant Storage:** The local SQLite binary resides inside OS-enforced application sandboxes (scoped app data directories) protected by file-system isolation.

1.2 Local Area Network (LAN) Peer-to-Peer Mesh

For high-throughput multi-terminal restaurant and retail environments, FlexiTap deploys a local peer-to-peer network mesh operating over local Wi-Fi/Ethernet without routing traffic outside the physical premises:

- **KDS & CDS Routing:** Orders punched at terminal registers broadcast directly to Kitchen Display Systems (KDS) and Customer Display Screens (CDS) over raw TCP sockets and local WebSockets on port 45455 with sub-millisecond latency.
- **ESC/POS Hardware Interface:** Thermal printers (network Ethernet/Wi-Fi, USB, and Bluetooth) receive raw ESC/POS raster and text commands directly from the terminal without cloud relays.
- **Terminal Health Heartbeats:** Real-time background monitors maintain socket pings between Master and Satellite terminals to guarantee high availability during network partitions.

1.3 Cloud Synchronization & Storage Architecture

FlexiTap pairs local autonomy with resilient cloud synchronization hosted on **Supabase (PostgreSQL 15+)** backed by AWS infrastructure:

- **Queued Outbox Synchronization:** When connectivity is present, the client SyncService processes queued mutations via an outbox queue. Writes use deterministic monotonic timestamps and tenant identifiers to resolve conflicts.
- **Private Automated Cloud Backups:** Daily automated database snapshots (.bak) are compressed via Gzip and uploaded to a private Supabase Storage bucket (backups/<store_id>/) with client-side 7-day retention rotation.
- **Tenant Isolation:** Storage buckets are configured with public = false, requiring authenticated JWT validation and strict path-matching policies before file retrieval.

1.4 Web Management Portal & Operations Architecture

The FlexiTap Back Office Web Portal (portal.html) and Operations Portal (dev-portal.html) provide desktop browser management:

- **Tenant-Scoped Analytics:** Live gross sales, hourly velocity, inventory alerts, recipe margins, and employee payroll hours.

- **Isolated Live Relays:** Real-time store events communicate over dedicated, tenant-validated broadcast channels (store_reports_relay_<storeId>), eliminating cross-tenant leakage.
- **Diagnostic Support Tunnel:** Remote desktop technical assistance utilizes on-demand RustDesk sessions activated strictly upon explicit merchant PIN entry and live supervision.

2. End-to-End Security Architecture & Controls

2.1 Multi-Layer Defense Matrix

FlexiTap implements a multi-tier defense-in-depth model spanning POS registers, cloud data storage, web portals, and operational access:

SECURITY DOMAIN	ENGINEERED CONTROL	IMPLEMENTATION LEVEL	STATUS
Multi-Tenant Isolation	PostgreSQL Row-Level Security (RLS) on all production tables enforcing store/owner identity	Database Engine (Supabase)	ENFORCED
Cloud Storage Security	Private bucket (public=false) with path-matching storage RLS functions on backups	Object Storage API	HARDENED
Public API Lockdown	Revocation of anon read/write permissions across all 10 legacy schema tables	DB Permissions (SQL)	ENFORCED
High-Privilege POS Guard	Manager/Admin PIN verification for Void, Refund, and Re-open in personal portal	Flutter Application Layer	VERIFIED
Web Portal Hardening	DOM text-node rendering, leads table attribute escaping, and sanitization	Web Client (Vanilla JS)	HARDENED
Role Escalation Guard	Removal of client-writable user_metadata.role from signup/dev-portal	Auth / Client Layer	BLOCKED
Relay Scoping	Channel segregation to store_reports_relay_<storeId> with parameter validation	Websocket Realtime	SECURED
Data in Transit	TLS 1.3 encryption across all HTTPS REST, Websocket, and OAuth endpoints	Cloudflare Edge / SSL	ACTIVE

2.2 Role-Based Access Control (RBAC) & PIN Security

POS terminals enforce strict operational role tiers: Cashier, Waiter, Kitchen Staff, Manager, and Admin/Owner.

- **Manager PIN Step-Up Authentication:** Any operation that alters audited financial or inventory balances (such as voiding an item post-kitchen dispatch, processing a refund, or reopening a finalized sale) triggers a modal challenge requiring an authorized Manager or Admin PIN via DatabaseService.instance.authenticatePin.
- **Personal Portal Scoping:** In My Personal Portal (employee_portal_screen.dart), cashiers are strictly scoped to their own closed tickets for the current shift. Cash drawer totals, shift sales summaries, and re-print operations are verified locally without transmitting sensitive employee PINs across unencrypted networks.

2.3 Database Row-Level Security (RLS) Architecture

Every public table in Supabase (including stores, devices, invoices, invoice_items, items, categories, taxes, merchant_leads, merchant_feedback, and remote_support_sessions) has Row-Level Security enabled:

RLS Policy Verification

Each query evaluates auth.uid() against the owning merchant record. Queries without a valid session token return empty sets or produce immediate 42501 Insufficient Privilege exceptions. The unauthenticated public role (anon) is completely revoked from data tables.

3. Payment Architecture & PCI DSS Boundary

3.1 Merchant of Record (Paddle) Architecture

FlexiTap operates under a **Merchant of Record (MoR)** partnership with **Paddle (Paddle.com Market Ltd)** for all cloud subscription billing, software licensing, and merchant payments.

- **PCI DSS Level 1 Certified Infrastructure:** All subscriber card details, payment tokens, CVVs, and billing addresses are collected directly inside Paddle's sandboxed iframes (Paddle.js v2). Credit card details never traverse, enter, or reside on FlexiTap servers, databases, or local app files.
- **Global Tax & Invoicing Compliance:** Paddle acts as the legal seller and Merchant of Record, automatically calculating, withholding, and remitting sales taxes, VAT, and GST across 200+ jurisdictions worldwide.
- **Cryptographic Webhook Validation:** Store license activations, tier renewals, and cancellations are verified via HMAC-SHA256 signatures before updating subscriber entitlements.

3.2 Retail Store Checkout (Cardholder Data Exclusion)

For in-store physical transactions at customer retail counters, FlexiTap maintains strict **PCI DSS Scope Exclusion**:

PAYMENT METHOD	PROCESSING CHANNEL	DATA STORED IN FLEXITAP
Physical Credit / Debit Cards	Stand-alone external payment terminal (EMV chip, NFC contactless, swipe) supplied by merchant acquirer	Operational metadata only: Payment type ('card'), external transaction ref, timestamp, and amount. **Zero PAN or CVV.**
Cash / Split Tender	Physical cash drawer driven by printer RJ12 pulse or manual kick	Amount tendered, change computed, drawer ledger movement.
E-Wallets / QR Ph / GCash / Maya	Dynamic or static QR code presented on screen or printed receipt	Reference number entered by cashier, confirmation status.
Customer Store Accounts (AR)	Local customer balance ledger with credit limit check	Customer ID, outstanding balance, credit ledger history.

> **Contractual & Technical PCI Exclusion Policy**
>
> Section 3 of the FlexiTap Terms of Service explicitly forbids entering or storing cardholder Primary Account Numbers (PANs), Card Verification Values (CVVs), or magnetic stripe track data in free-text item notes, customer notes, or transaction remarks. This architectural separation completely removes FlexiTap servers and databases from PCI DSS Cardholder Data Environment (CDE) scope.

4. Terms, Privacy Policy & Regulatory Framework

4.1 Legal Role Demarcation: Controller vs. Processor

In accordance with the General Data Protection Regulation (GDPR Art. 4), the California Consumer Privacy Act (CCPA/CPRA), and the Philippine Data Privacy Act of 2012 (RA 10173):

- **FlexiTap as Data Controller (PIC):** FlexiTap acts as Data Controller only for merchant account registration details (merchant business email, store profile, and billing token issued by Paddle).
- **FlexiTap as Data Processor (PIP):** For all consumer records, customer phone numbers, loyalty points, employee attendance times, and sales transactions entered into the system by the merchant, **the merchant acts as sole Data Controller (PIC)** and FlexiTap acts strictly as Data Processor (PIP), processing records exclusively on the merchant's operational instructions.

4.2 Four Protective Statutory Disclaimers

The FlexiTap legal framework embeds four critical protective clauses across terms.html and privacy.html:

PROTECTIVE CLAUSE	CONTRACTUAL PROVISION	LEGAL / REGULATORY OBJECTIVE
1. PCI DSS Exclusion	Explicit ban on storing 16-digit PANs, CVVs, or chip data in free-text fields; card checkout must use external certified terminals.	Eliminates PCI DSS merchant audit liability and CDE footprint.
2. HIPAA & PHI Exclusion	Express disclaimer that FlexiTap is not a Covered Entity or Business Associate; bans storage of patient health information (PHI).	Shields from healthcare privacy regulations and compliance overhead.
3. BIR Non-OR Notice (PH)	Express declaration under RA 8424 and RR 11-2004 that slips are internal kitchen/order records, NOT statutory Official Receipts.	Protects against Philippine tax non-compliance or Oplan Kandado exposure.
4. Wage & Overtime Disclaimer	Confirms timeclock records are operational tracking tools; merchant holds sole duty for FLSA/Labor Code wage and overtime rules.	Shields from statutory labor disputes, employee wage claims, and penalties.

4.3 Privacy Governance & Data Subject Rights

- **Zero Data Monetization:** FlexiTap does not sell, rent, or trade merchant or consumer data to brokers, advertisers, or third parties. The software is 100% ad-free across all tiers.
- **Right to Erasure & Account Deletion:** Merchants can permanently delete their account and associated operational cloud backups via the automated self-service endpoint at https://flexitapapp.com/account/delete.
- **Private Cloud Backups:** Subscribers with cloud backup features have database archives stored encrypted in private Supabase Storage buckets, purged upon account cancellation or 7-day client rotation.

4.4 Refund Policy Framework

FlexiTap maintains a transparent, merchant-friendly refund standard:

- **14-Day Statutory Guarantee:** First-time paid subscribers can request a full, no-questions-asked refund within 14 calendar days of initial purchase by contacting support@flexitapapp.com.

- **Hassle-Free Self-Service Cancellation:** Subscriptions can be canceled at any time via the Back Office Web Portal or the Paddle Customer Dashboard, halting future renewals immediately while retaining access until cycle conclusion.

5. Independent Audit Readiness & Certification Matrix

5.1 Technical Compliance Verification Matrix

REGULATORY STANDARD	PLATFORM POSITION / SCOPE	VERIFICATION EVIDENCE	AUDIT RECOMMENDATION
PCI DSS v4.0	**Excluded from Scope**. Zero PAN/CVV storage; SaaS billing offloaded to Paddle (Level 1 MoR); POS uses external card terminals.	terms.html Sec 3, privacy.html Sec 2, architecture audit	COMPLIANT VIA EXCLUSION
GDPR / UK GDPR	**Compliant Data Processor**. Role clarity, DPA clauses, encryption in transit/rest, right to erasure via self-service endpoint.	privacy.html Sec 1 & 9, account deletion handler	VERIFIED
CCPA / CPRA	**Compliant Service Provider**. No sale or sharing of personal information; support for consumer deletion and access rights.	privacy.html Sec 9, web data protection disclosures	VERIFIED
PH DPA (RA 10173)	**Compliant PIP**. Adheres to Section 16 rights, NPC reporting framework, technical encryption, and security disclaimers.	privacy.html Sec 9 schedule, security measures doc	VERIFIED
HIPAA / HITECH	**Excluded from Scope**. Software expressly disclaims use for patient Protected Health Information (PHI).	terms.html Sec 7, privacy.html Sec 2	EXCLUDED VIA TERMS
Philippine BIR PTU	**Operational Control Tool**. Clarified as non-fiscal internal order printer; merchants must issue manual registered BIR receipts.	terms.html Sec 8 BIR Schedule, customer slip footer	CLEAR LEGAL NOTICE
US FLSA & Labor Laws	**Operational Time Tracker**. Timecards are uncertified raw logs; merchant holds sole duty for wage/overtime calculations.	terms.html Sec 8 Labor Schedule	PROTECTED

5.2 Platform Hardening Summary

The FlexiTap platform has undergone comprehensive security engineering, including:

1. **Database Hardening:** RLS enabled across 100% of public tables, elimination of anon public table privileges, and isolation of backup buckets.
2. **POS Financial Protection:** Manager PIN step-up authentication safeguarding Voids, Refunds, and Re-openings within cashier workflows.
3. **Frontend Defenses:** Elimination of DOM XSS injection vectors, sanitization of web tables, and blocking of client-side role privilege escalation.
4. **Network Isolation:** Tenant-scoped WebSocket real-time channels and TLS 1.3 encryption across all communication pathways.

Conclusion & Auditor Attestation

The architectural, security, payment, and legal measures implemented across the FlexiTap POS platform represent an enterprise-grade, privacy-first posture suitable for retail, restaurant, and enterprise merchant deployments globally.

INDEPENDENT REVIEWER SIGN-OFF SECTION

Auditor Name: _____ Signature: _____

Review Firm / Title: _____ Date of Review: _____